

Wireless Network Security

CRYPTOGRAPHY AND NETWORK SECURITY

- **Why Wireless is Insecure?**
 - **Channel: Broadcast $\Rightarrow$ Eavesdropping, Jamming, Active attacks on protocols**
 - **Mobility: Portable devices $\Rightarrow$ Not physically secured**
 - **Resources: Limited memory and processing resources $\Rightarrow$ Need simpler security**
 - **Accessibility: May be left unattended**

Wireless Network Threats

- **Accidental association:** Company wireless LANs or wireless access points to wired LANs in close proximity (e.g., in the same or neighboring buildings) may create overlapping transmission ranges. A user intending to connect to one LAN may unintentionally lock on to a wireless access point from a neighboring network. Although the security breach is accidental, it nevertheless exposes resources of one LAN to the accidental user.
- **Malicious association:** In this situation, a wireless device is configured to appear to be a legitimate access point, enabling the operator to steal passwords from legitimate users and then penetrate a wired network through a legitimate wireless access point.
- **Ad hoc networks:** These are peer-to-peer networks between wireless computers with no access point between them. Such networks can pose a security threat due to a lack of a central point of control.
- **Nontraditional networks:** Nontraditional networks and links, such as personal network Bluetooth devices, barcode readers, and handheld PDAs, pose a security risk in terms of both eavesdropping and spoofing.

Wireless Network Threats

- **Identity theft (MAC spoofing):** This occurs when an attacker is able to eavesdrop on network traffic and identify the MAC address of a computer with network privileges.
- **Man-in-the middle attacks:** This attack involves persuading a user and an access point to believe that they are talking to each other when in fact the communication is going through an intermediate attacking device. Wireless networks are particularly vulnerable to such attacks.
- **Denial of service (DoS):** In the context of a wireless network, a DoS attack occurs when an attacker continually bombards a wireless access point or some other accessible wireless port with various protocol messages designed to consume system resources. The wireless environment lends itself to this type of attack, because it is so easy for the attacker to direct multiple wireless messages at the target.
- **Network injection:** A network injection attack targets wireless access points that are exposed to nonfiltered network traffic, such as routing protocol messages or network management messages. An example of such an attack is one in which bogus reconfiguration commands are used to affect routers and switches to degrade network performance.

Wireless Security Measures

- we can group wireless security measures into those dealing with wireless transmissions, wireless access points, and wireless networks (consisting of wireless routers and endpoints).

Securing WireleSS TranSmiSSionS

- The principal threats to wireless transmission are eavesdropping, altering or inserting messages, and disruption. To deal with eavesdropping, two types of countermeasures are appropriate:
 - **Signal-hiding techniques:** Organizations can take a number of measures to make it more difficult for an attacker to locate their wireless access points, including turning off service set identifier (SSID) broadcasting by wireless access points; assigning cryptic names to SSIDs; reducing signal strength to the lowest level that still provides requisite coverage; and locating wireless access points in the interior of the building, away from windows and exterior walls. Greater security can be achieved by the use of directional antennas and of signal-shielding techniques.
 - **Encryption:** Encryption of all wireless transmission is effective against eavesdropping to the extent that the encryption keys are secured.

Securing WireleSS acceSS PoinTS

- The main threat involving wireless access points is unauthorized access to the network.
- The principal approach for preventing such access is the IEEE 802.1X standard for port-based network access control.
- The standard provides an authentication mechanism for devices wishing to attach to a LAN or wireless network.
- The use of 802.1X can prevent rogue access points and other unauthorized devices from becoming insecure backdoors.

SECURING WIRELESS NETWORKS

- The following techniques for wireless network security:
 - Use encryption. Wireless routers are typically equipped with built-in encryption mechanisms for router-to-router traffic.
 - Use antivirus and antispyware software, and a firewall. These facilities should be enabled on all wireless network endpoints.
 - Turn off identifier broadcasting. Wireless routers are typically configured to broadcast an identifying signal so that any device within range can learn of the router's existence. If a network is configured so that authorized devices know the identity of routers, this capability can be disabled, so as to thwart attackers.
 - Change the identifier on your router from the default. Again, this measure thwarts attackers who will attempt to gain access to a wireless network using default router identifiers.
 - Change your router's pre-set password for administration. This is another prudent step.
 - Allow only specific computers to access your wireless network. A router can be configured to only communicate with approved MAC addresses. Of course, MAC addresses can be spoofed, so this is just one element of a security strategy.

Wireless Security Measures

- Turn-off SSID broadcast
- Use Cryptic SSID names
- Reduce signal strength
- Locate APs away from boundary
- Use encryption
- Use IEEE 802.1x network access control
- Change the router's user ID from default
- Change the router's password from default
- MAC Filtering: Only specific MAC address connect

Mobile Device Security

- Prior to the widespread use of smartphones, the dominant paradigm for computer and network security in organizations was as follows.
- Corporate IT was tightly controlled. User devices were typically limited to Windows PCs.
- Business applications were controlled by IT and either run locally on endpoints or on physical servers in data centers.
- Network security was based upon clearly defined perimeters that separated trusted internal networks from the untrusted Internet.
- Since then, there have been massive changes in each of these assumptions.

Mobile Device Security

- **Growing use of new devices:** Organizations are experiencing significant growth in employee use of mobile devices. In many cases, employees are allowed to use a combination of endpoint devices as part of their day-to-day activities.
- **Cloud-based applications:** Applications no longer run solely on physical servers in corporate data centers. Quite the opposite, applications can run anywhere—on traditional physical servers, on mobile virtual servers, or in the cloud. Additionally, end users can now take advantage of a wide variety of cloud-based applications and IT services for personal and professional use. Facebook can be used for an employee's personal profiles or as a component of a corporate marketing campaign. Employees depend upon Skype to speak with friends abroad or for legitimate business video conferencing. Dropbox and Box can be used to distribute documents between corporate and personal devices for mobility and user productivity.

Mobile Device Security

- **De-perimeterization:** Given new device proliferation, application mobility, and cloud-based consumer and corporate services, the notion of a static network perimeter is all but gone. Now there are a multitude of network perimeters around devices, applications, users, and data. These perimeters have also become quite dynamic as they must adapt to various environmental conditions such as user role, device type, server virtualization mobility, network location, and time-of-day.
- **External business requirements:** The enterprise must also provide guests, third-party contractors, and business partners network access using various devices from a multitude of locations.
- **The central element in all of these changes is the mobile computing device. Mobile devices have become an essential element for organizations as part of the overall network infrastructure.**

Mobile Device Security Threats

- Mobile $\Rightarrow$ Dynamic/no boundary $\Rightarrow$ Cloud
- Lack of Physical security: Mobiles cannot be locked
- Not all devices can be trusted
- Untrusted networks between device and the organization
- Wide variety of contents on mobiles than on other computers (music, video, games, ...)
- Apps from untrusted vendors
- Data may get on unsecured device
- Location information may be used for attack

Mobile Device Security Strategy

- The principal elements of a mobile device security strategy fall into three categories: device security, client/server traffic security, and barrier security

DEVICE SECURITY

- A number of organizations will supply mobile devices for employee use and preconfigure those devices to conform to the enterprise security policy.
- However, many organizations will find it convenient or even necessary to adopt a bring-your-own-device (BYOD) policy that allows the personal mobile devices of employees to have access to corporate resources.
- IT managers should be able to inspect each device before allowing network access.
- IT will want to establish configuration guidelines for operating systems and applications.

Whether a device is **owned by the organization or BYOD**, the organization should configure the device with security controls, including the following:

- Enable auto-lock, which causes the device to lock if it has not been used for a given amount of time, requiring the user to re-enter a four-digit PIN or a password to re-activate the device.
- Enable password or PIN protection. The PIN or password is needed to unlock the device. In addition, it can be configured so that email and other data on the device are encrypted using the PIN or password and can only be retrieved with the PIN or password.
- Avoid using auto-complete features that remember user names or passwords.
- Enable remote wipe.
- Ensure that SSL protection is enabled, if available.
- Make sure that software, including operating systems and applications, is up to date.
- Install antivirus software as it becomes available.

Whether a device is **owned by the organization or BYOD**, the organization should configure the device with security controls, including the following:

- Either sensitive data should be prohibited from storage on the mobile device or it should be encrypted.
- IT staff should also have the ability to remotely access devices, wipe the device of all data, and then disable the device in the event of loss or theft.
- The organization may prohibit all installation of third-party applications, implement whitelisting to prohibit installation of all unapproved applications, or implement a secure sandbox that isolates the organization's data and applications from all other data and applications on the mobile device. Any application that is on an approved list should be accompanied by a digital signature and a public-key certificate from an approved authority.
- The organization can implement and enforce restrictions on what devices can synchronize and on the use of cloud-based storage.
- To deal with the threat of untrusted content, security responses can include training of personnel on the risks inherent in untrusted content and disabling camera use on corporate mobile devices.
- To counter the threat of malicious use of location services, the security policy can dictate that such service is disabled on all mobile devices.

TRAFFIC SECURITY

- Traffic security is based on the usual mechanisms for encryption and authentication.
- All traffic should be encrypted and travel by secure means, such as SSL or IPv6.
- Virtual private networks (VPNs) can be configured so that all traffic between the mobile device and the organization's network is via a VPN.
- A strong authentication protocol should be used to limit the access from the device to the resources of the organization.
- Often, a mobile device has a single device-specific authenticator, because it is assumed that the device has only one user.
- A preferable strategy is to have a two-layer authentication mechanism, which involves authenticating the device and then authenticating the user of the device.

BARRIER SECURITY

- The organization should have security mechanisms to protect the network from unauthorized access.
- The security strategy can also include firewall policies specific to mobile device traffic.
- Firewall policies can limit the scope of data and application access for all mobile devices.
- Similarly, intrusion detection and intrusion prevention systems can be configured to have tighter rules for mobile device traffic.

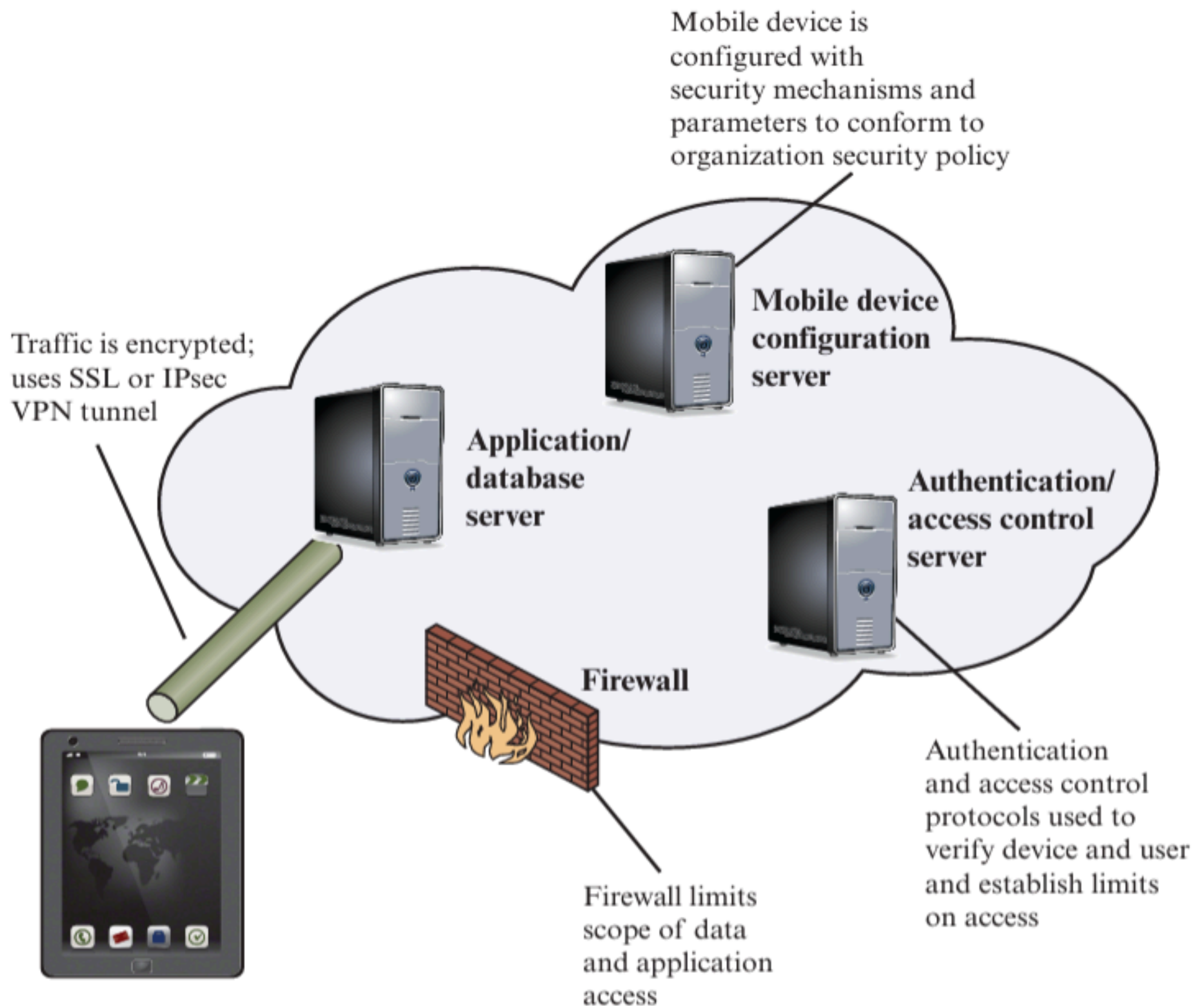


Figure 18.2 Mobile Device Security Elements

IEEE 802.11 WIRELESS LAN

- IEEE 802 is a committee that has developed standards for a wide range of local area networks (LANs).
- In 1990, the IEEE 802 Committee formed a new working group, IEEE 802.11, with a charter to develop a protocol and transmission specifications for wireless LANs (WLANs).

Table 18.1 IEEE 802.11 Terminology

Access point (AP)	Any entity that has station functionality and provides access to the distribution system via the wireless medium for associated stations.
Basic service set (BSS)	A set of stations controlled by a single coordination function.
Coordination function	The logical function that determines when a station operating within a BSS is permitted to transmit and may be able to receive PDUs.
Distribution system (DS)	A system used to interconnect a set of BSSs and integrated LANs to create an ESS.
Extended service set (ESS)	A set of one or more interconnected BSSs and integrated LANs that appear as a single BSS to the LLC layer at any station associated with one of these BSSs.
MAC protocol data unit (MPDU)	The unit of data exchanged between two peer MAC entities using the services of the physical layer.
MAC service data unit (MSDU)	Information that is delivered as a unit between MAC users.
Station	Any device that contains an IEEE 802.11 conformant MAC and physical layer.

The Wi-Fi Alliance

- The first 802.11 standard to gain broad industry acceptance was 802.11b. Although 802.11b products are all based on the same standard, there is always a concern whether products from different vendors will **successfully interoperate**.
- To meet this concern, the **Wireless Ethernet Compatibility Alliance (WECA)**, an industry consortium, was formed in 1999. This organization, subsequently renamed the **Wi-Fi (Wireless Fidelity) Alliance**, created a test suite to certify interoperability for 802.11b products.
- The term used for certified 802.11b products is **Wi-Fi**.
- Wi-Fi certification has been extended to 802.11g products. The Wi-Fi Alliance has also developed a certification process for 802.11a products, called Wi-Fi5. The Wi-Fi Alliance is concerned with a range of market areas for WLANs, including enterprise, home, and hot spots.
- **More recently, the Wi-Fi Alliance has developed certification procedures for IEEE 802.11 security standards, referred to as Wi-Fi Protected Access (WPA). The most recent version of WPA, known as WPA2, incorporates all of the features of the IEEE 802.11i WLAN security specification.**

IEEE 802 Protocol Architecture

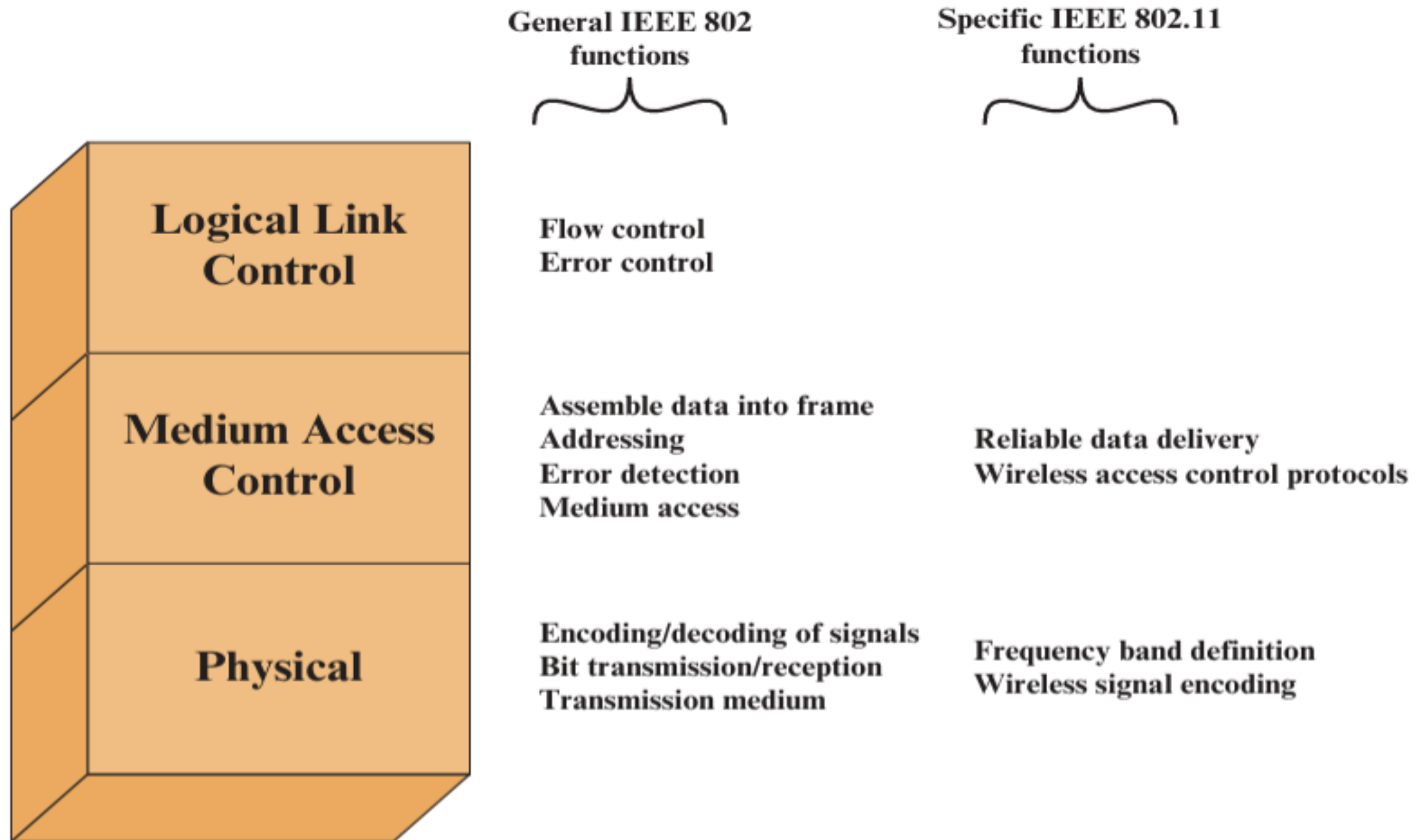


Figure 18.3 IEEE 802.11 Protocol Stack

PhySical layer

- The lowest layer of the IEEE 802 reference model is the physical layer, which includes such functions as encoding/decoding of signals and bit transmission/reception.
- In addition, the physical layer includes a specification of the transmission medium. In the case of IEEE 802.11, the physical layer also defines frequency bands and antenna characteristics.

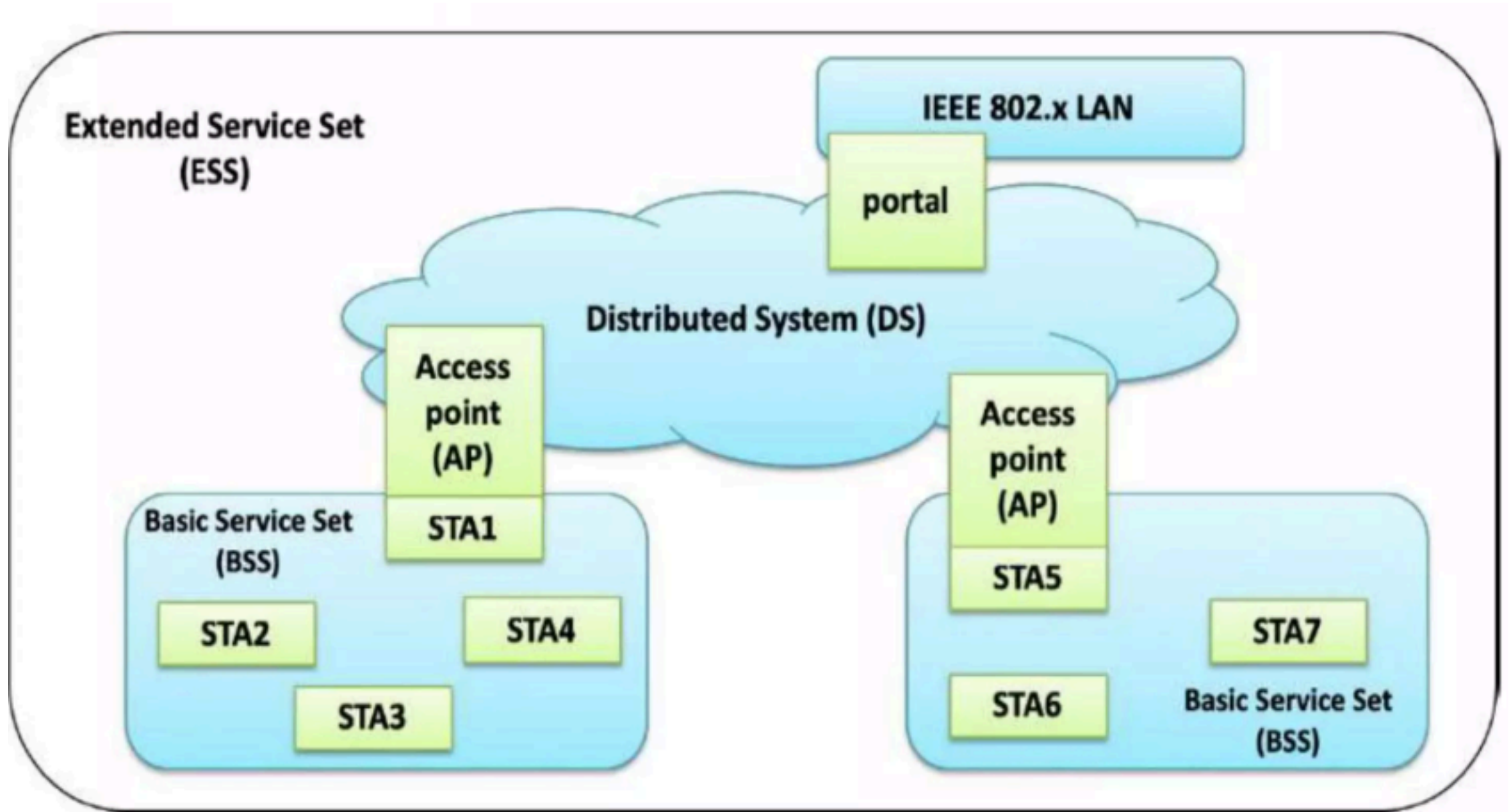
MEDIA ACCESS CONTROL

- All LANs consist of collections of devices that share the network's transmission capacity. Some means of controlling access to the transmission medium is needed to provide an orderly and efficient use of that capacity. This is the function of a media access control (MAC) layer.
- The MAC layer receives data from a higher-layer protocol, typically the Logical Link Control (LLC) layer, in the form of a block of data known as the MAC service data unit (MSDU). In general, the MAC layer performs the following functions:
 - On transmission, assemble data into a frame, known as a MAC protocol data unit (MPDU) with address and error-detection fields.
 - On reception, disassemble frame, and perform address recognition and error detection.
 - Govern access to the LAN transmission medium.

LOGICAL LINK CONTROL

- In most data-link control protocols, the data-link protocol entity is responsible not only for detecting errors using the CRC, but for recovering from those errors by retransmitting damaged frames.
- In the LAN protocol architecture, these two functions are split between the MAC and LLC layers.
- The MAC layer is responsible for detecting errors and discarding any frames that contain errors.
- The LLC layer optionally keeps track of which frames have been successfully received and retransmits unsuccessful frames.

IEEE 802.11 Network Components and Architectural Model



IEEE 802.11 Network Components and Architectural Model

- Basic Service Area (BSA) = Cell
- Each BSA may have several access points (APs)
- Basic Service Set (BSS) = Set of stations associated with one AP
- Distribution System (DS) - wired backbone
- Extended Service Area (ESA) = Multiple BSAs interconnected via a distribution system
- Extended Service Set (ESS) = Set of stations in an ESA
- Independent Basic Service Set (IBSS): Set of computers in ad-hoc mode. May not be connected to wired backbone.
- Ad-hoc networks coexist and interoperate with infrastructure-based networks

IEEE 802.11 Services

- **Association:** A STA connecting with an AP.
- **Disassociation:** Termination of association.
- **Re-association:** Transfer of association from one AP to another. Mobility within BSS, within ESS, between two ESSs.
- **MSDU Delivery:** Interchange of packets between STAs
- **Distribution:** Delivery of packets between STAs possibly via the backbone distribution system
- **Integration:** Interchange of packets between STAs and wired stations connected to LANs on the distribution system
- **Authentication:** The station is authenticated
- **De-authentication**

Table 18.2 IEEE 802.11 Services

Service	Provider	Used to support
Association	Distribution system	MSDU delivery
Authentication	Station	LAN access and security
Deauthentication	Station	LAN access and security
Disassociation	Distribution system	MSDU delivery
Distribution	Distribution system	MSDU delivery
Integration	Distribution system	MSDU delivery
MSDU delivery	Station	MSDU delivery
Privacy	Station	LAN access and security
Reassociation	Distribution system	MSDU delivery

There are two characteristics of a wired LAN that are not inherent in a wireless LAN

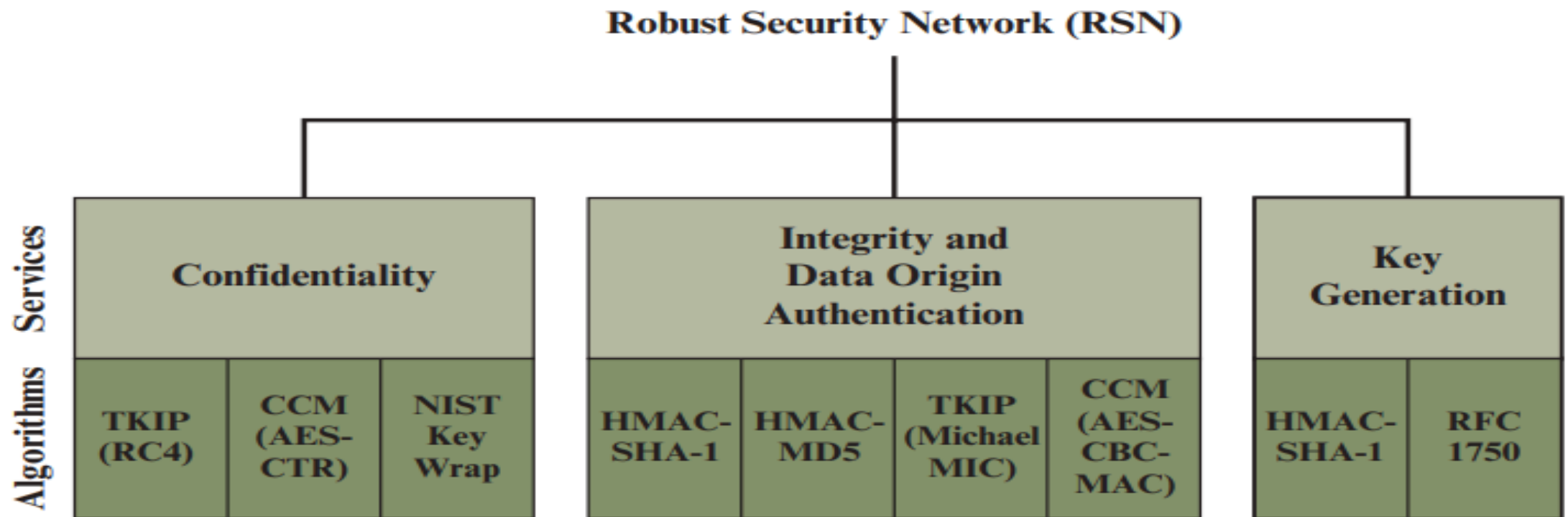
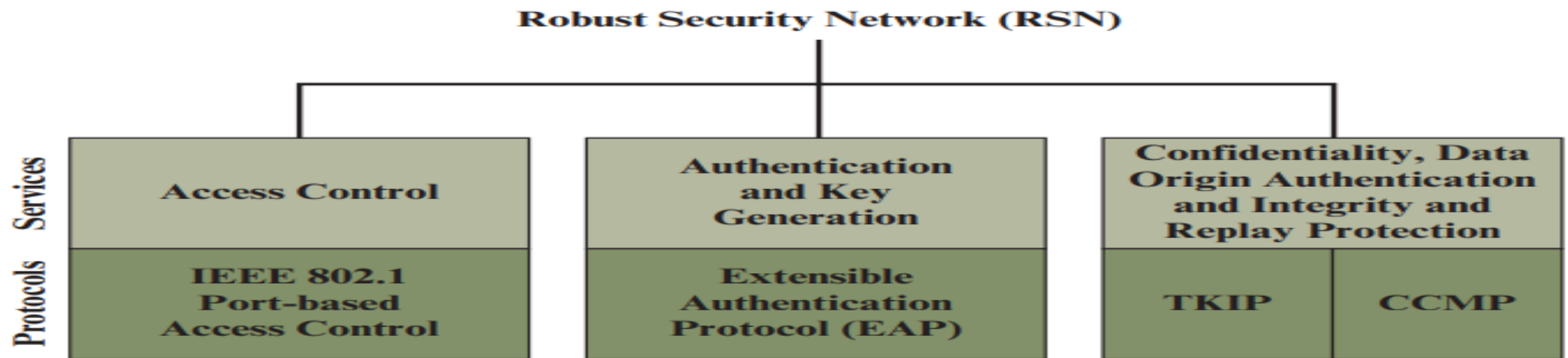
- In order to transmit over a wired LAN, a station must be physically connected to the LAN. On the other hand, with a wireless LAN, any station within radio range of the other devices on the LAN can transmit. In a sense, there is a form of authentication with a wired LAN in that it requires some positive and presumably observable action to connect a station to a wired LAN.
- Similarly, in order to receive a transmission from a station that is part of a wired LAN, the receiving station also must be attached to the wired LAN. On the other hand, with a wireless LAN, any station within radio range can receive. Thus, a wired LAN provides a degree of privacy, limiting reception of data to stations connected to the LAN.
- These differences between wired and wireless LANs suggest the increased need for robust security services and mechanisms for wireless LANs

- For privacy, 802.11 defined the **Wired Equivalent Privacy (WEP)** algorithm.
- The privacy portion of the 802.11 standard contained major weaknesses. Subsequent to the development of WEP, the 802.11i task group has developed a set of capabilities to address the WLAN security issues.
- In order to accelerate the introduction of strong security into WLANs, the Wi-Fi Alliance promulgated **Wi-Fi Protected Access (WPA) as a Wi-Fi standard**.
- WPA is a set of security mechanisms that eliminates most 802.11 security issues and was based on the current state of the 802.11i standard.
- The final form of the 802.11i standard is referred to as **Robust Security Network (RSN)**.
- The Wi-Fi Alliance certifies vendors in compliance with the full 802.11i specification under the WPA2 program.

IEEE 802.11i RSN Security Services

- Authentication: A protocol is used to define an exchange between a user and an AS that provides mutual authentication and generates temporary keys to be used between the client and the AP over the wireless link.
- Access control: This function enforces the use of the authentication function, routes the messages properly, and facilitates key exchange. It can work with a variety of authentication protocols.
- Privacy with message integrity: MAC-level data (e.g., an LLC PDU) are encrypted along with a message integrity code that ensures that the data have not been altered.

Security Protocols used to support these services & Cryptographic Algorithms used for these services

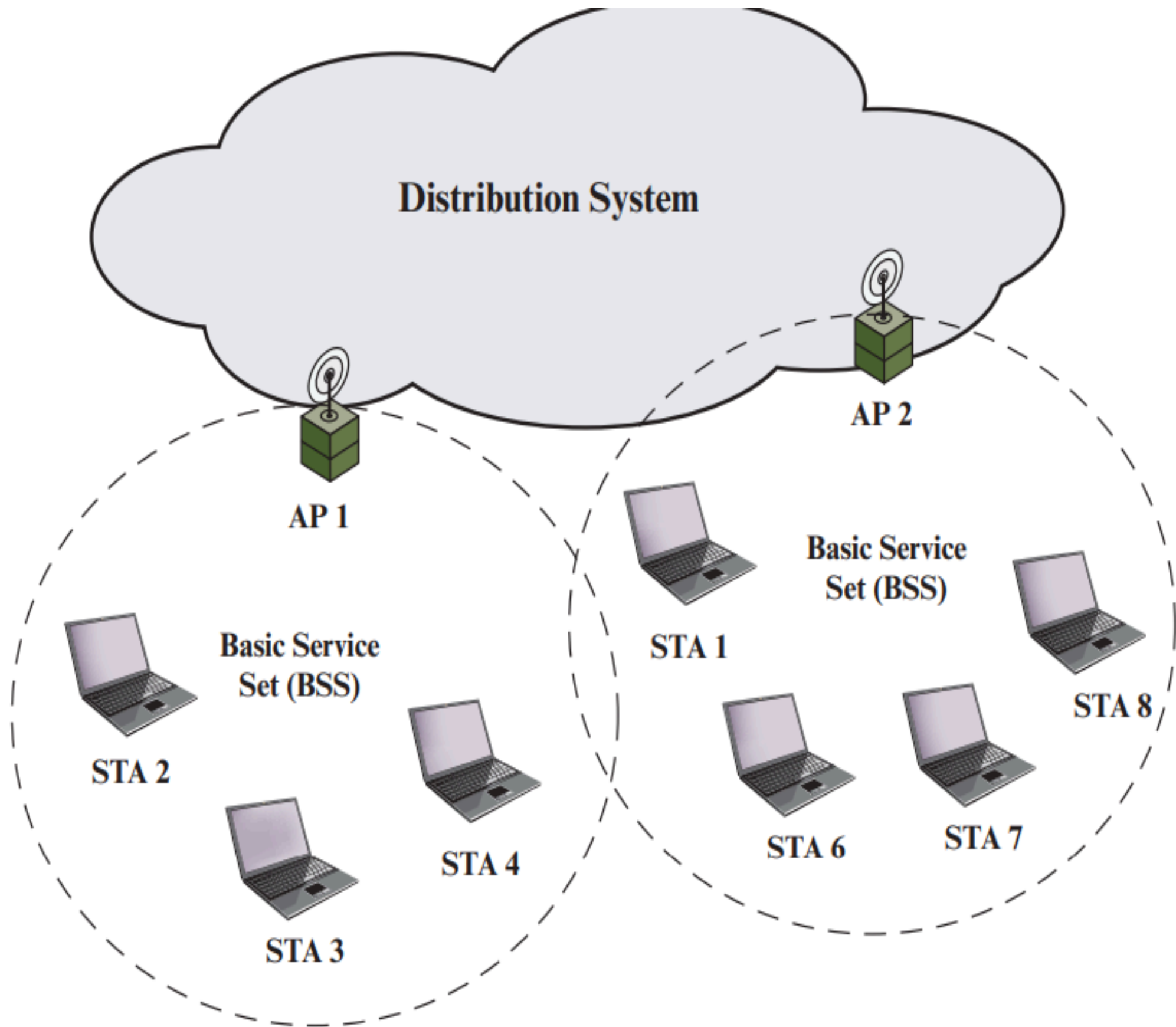


(b) Cryptographic algorithms

- CBC-MAC** = Cipher Block Chaining Message Authentication Code (MAC)
- CCM** = Counter Mode with Cipher Block Chaining Message Authentication Code
- CCMP** = Counter Mode with Cipher Block Chaining MAC Protocol
- TKIP** = Temporal Key Integrity Protocol

IEEE 802.11i Phases of Operation

- The operation of an IEEE 802.11i RSN can be broken down into five distinct phases of operation. The exact nature of the phases will depend on the configuration and the end points of the communication.
 - Possibilities include
 - Two wireless stations in the same BSS communicating via the access point (AP) for that BSS.
 - Two wireless stations (STAs) in the same ad hoc IBSS communicating directly with each other.
 - Two wireless stations in different BSSs communicating via their respective APs across a distribution system.
 - A wireless station communicating with an end station on a wired network via its AP and the distribution system.
- IEEE 802.11i security is concerned only with secure communication between the STA and its AP**



Five phases of operation for an RSN

- **Discovery:** An AP uses messages called Beacons and Probe Responses to advertise its IEEE 802.11i security policy. The STA uses these to identify an AP for a WLAN with which it wishes to communicate. The STA associates with the AP, which it uses to select the cipher suite and authentication mechanism when the Beacons and Probe Responses present a choice.
- **Authentication:** During this phase, the STA and AS prove their identities to each other. The AP blocks non-authentication traffic between the STA and AS until the authentication transaction is successful. The AP does not participate in the authentication transaction other than forwarding traffic between the STA and AS.
- **Key generation and distribution:** The AP and the STA perform several operations that cause cryptographic keys to be generated and placed on the AP and the STA. Frames are exchanged between the AP and STA only.
- **Protected data transfer:** Frames are exchanged between the STA and the end station through the AP. As denoted by the shading and the encryption module icon, secure data transfer occurs between the STA and the AP only; security is not provided end-to-end.
- **Connection termination:** The AP and STA exchange frames. During this phase, the secure connection is torn down and the connection is restored to the original state

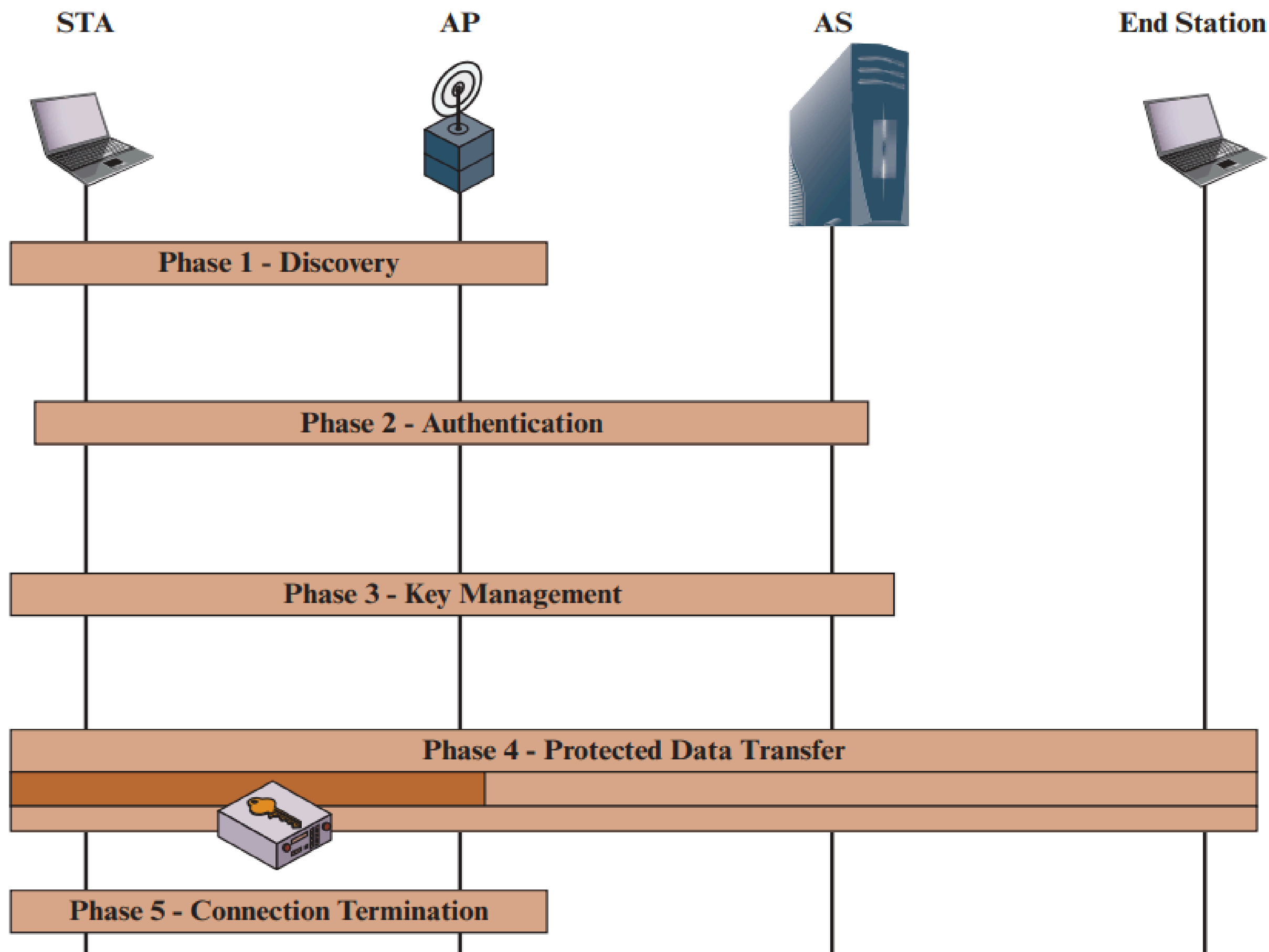


Figure 18.7 IEEE 802.11i Phases of Operation

Discovery Phase

- The purpose of this phase is for an STA and an AP to recognize each other, agree on a set of security capabilities, and establish an association for future communication using

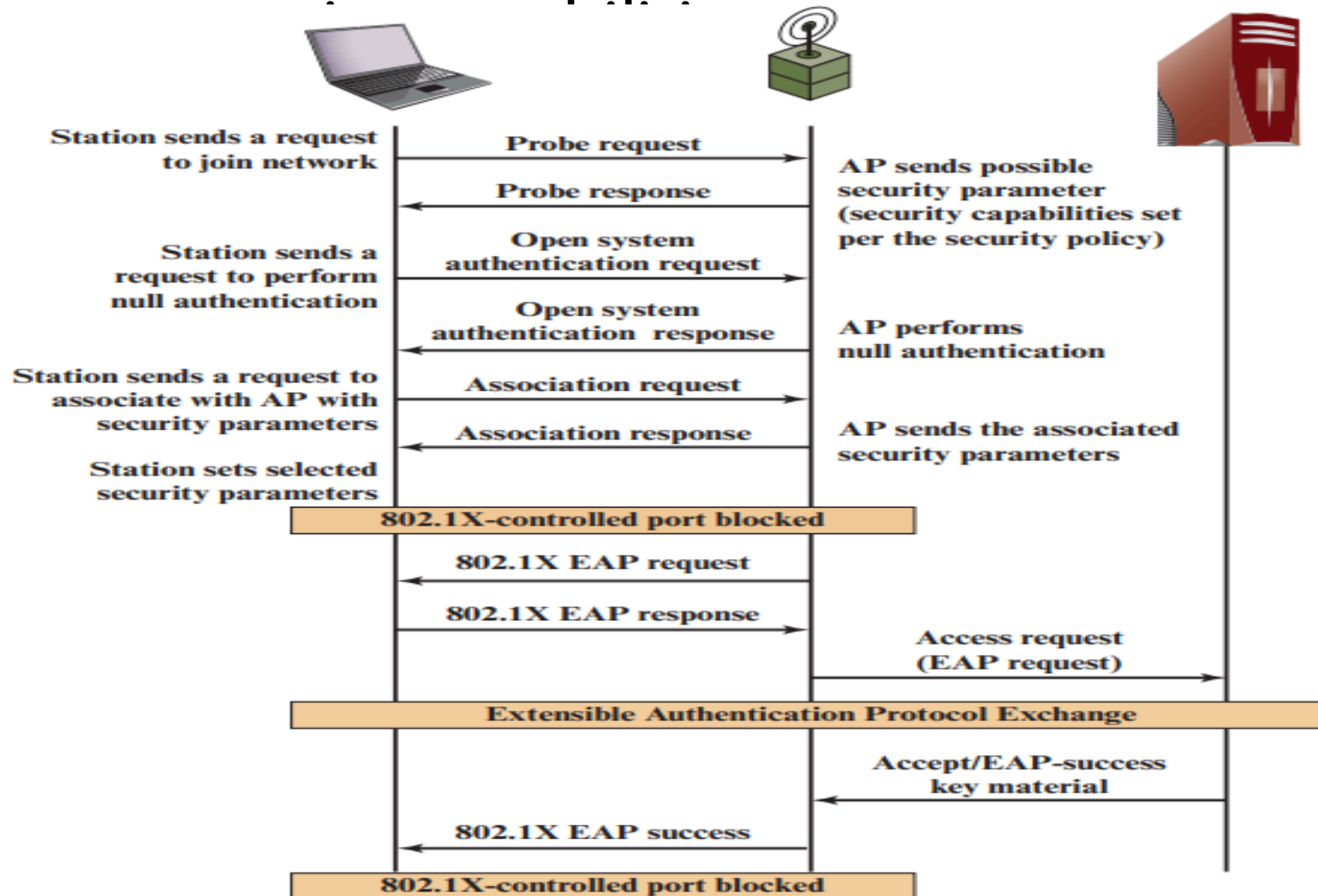


Figure 18.8 IEEE 802.11i Phases of Operation: Capability Discovery, Authentication, and Association

Security Capabilities

- During this phase, the STA and AP decide on specific techniques in the following areas:
 - Confidentiality and MPDU integrity protocols for protecting unicast traffic (traffic only between this STA and AP)
 - Authentication method
 - Cryptography key management approach
- The options for the confidentiality and integrity cipher suite are
 - WEP, with either a 40-bit or 104-bit key, which allows backward compatibility with older IEEE 802.11 implementations
 - TKIP
 - CCMP
 - Vendor-specific methods

AUTHENTICATION AND KEY MANAGEMENT (AKM) SUITE

- The other negotiable suite is the authentication and key management (AKM) suite, which defines (1) the means by which the AP and STA perform mutual authentication and (2) the means for deriving a root key from which other keys may be generated.
- The possible AKM suites are
 - IEEE 802.1X
 - Pre-shared key (no explicit authentication takes place and mutual authentication is implied if the STA and AP share a unique secret key)
 - Vendor-specific methods

MPDU Exchange The discovery phase consists of three exchanges.

- Network and security capability discovery: During this exchange, STAs discover the existence of a network with which to communicate. The AP either periodically broadcasts its security capabilities or responds to a station's Probe Request through a Probe Response frame
- Open system authentication
- Association: The purpose of this stage is to agree on a set of security capabilities to be used. The STA then sends an Association Request frame to the AP

Authentication Phase

- Authentication phase enables mutual authentication between an STA and an authentication server (AS) located in the DS.
- Authentication is designed to allow only authorized stations to use the network and to provide the STA with assurance that it is communicating with a legitimate network.

IEEE 802.1X Access Control Approach

- IEEE 802.11i makes use of another standard that was designed to provide access control functions for LANs.
- The standard is IEEE 802.1X, Port-Based Network Access Control.
- The authentication protocol that is used, the **Extensible Authentication Protocol (EAP)**, is defined in the IEEE 802.1X standard.
- IEEE 802.1X uses the terms **supplicant, authenticator, and authentication server (AS)**.

Authentication phase consists of the following three phases.

- **Connect to AS:** The STA sends a request to its AP (the one with which it has an association) for connection to the AS. The AP acknowledges this request and sends an access request to the AS.
- **EAP exchange:** This exchange authenticates the STA and AS to each other. A number of alternative exchanges are possible, as explained subsequently.
- **Secure key delivery:** Once authentication is established, the AS generates a master session key (MSK), also known as the Authentication, Authorization, and Accounting (AAA) key and sends it to the STA.

EAP Exchange

- There are a number of possible EAP exchanges that can be used during the authentication phase.
- Typically, the message flow between STA and AP employs the **EAP over LAN (EAPOL) protocol**, and the message flow between the AP and AS uses the **Remote Authentication Dial In User Service (RADIUS) protocol**

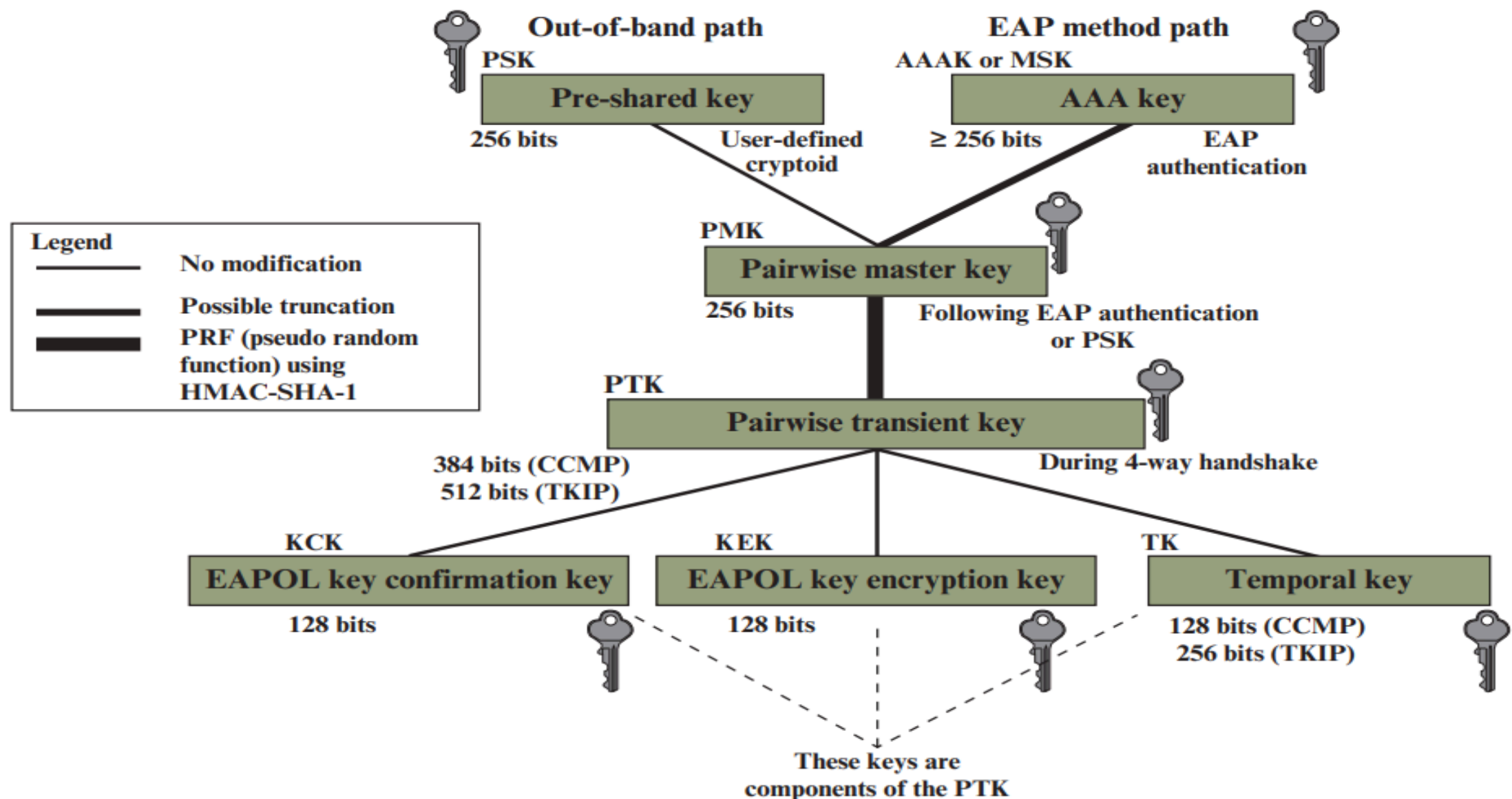
Authentication exchange using EAPOL and RADIUS

- The EAP exchange begins with the AP issuing an EAP-Request/Identity frame to the STA.
- The STA replies with an EAP-Response/Identity frame, which the AP receives over the uncontrolled port. The packet is then encapsulated in RADIUS over EAP and passed on to the RADIUS server as a RADIUS-Access-Request packet.
- The AAA server replies with a RADIUS-Access-Challenge packet, which is passed on to the STA as an EAP-Request. This request is of the appropriate authentication type and contains relevant challenge information.
- The STA formulates an EAP-Response message and sends it to the AS. The response is translated by the AP into a Radius-Access-Request with the response to the challenge as a data field
- The AAA server grants access with a Radius-Access-Accept packet. The AP issues an EAP-Success frame. (Some protocols require confirmation of the EAP success inside the TLS tunnel for authenticity validation) The controlled port is authorized and the

Key Management Phase

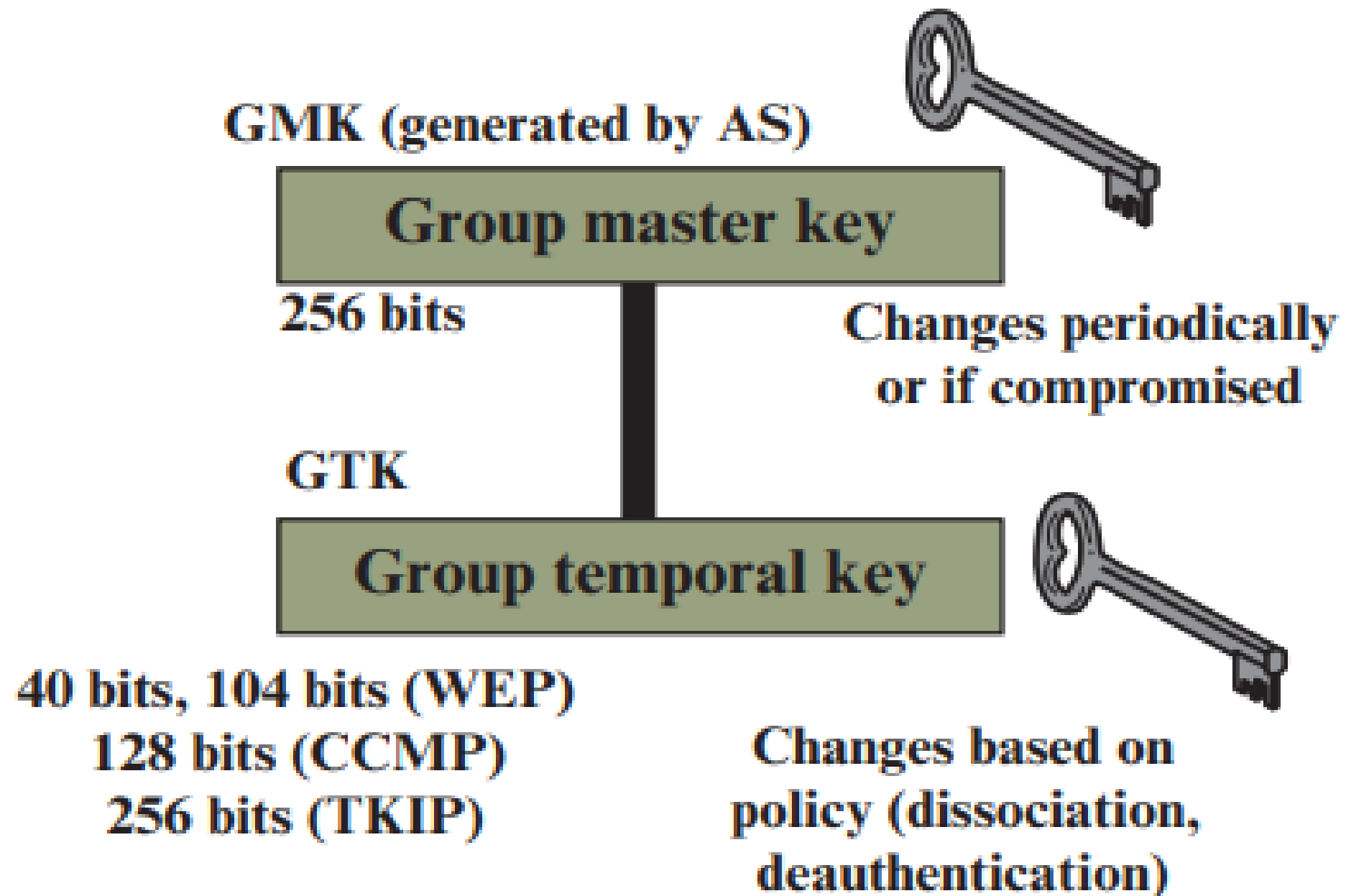
- During the key management phase, a variety of cryptographic keys are generated and distributed to STAs.
- There are two types of keys: **pairwise keys** used for communication between an STA and an AP and **group keys** used for multicast communication.

Pairwise keys are used for communication between a pair of devices, typically between an STA and an AP. These keys form a hierarchy beginning with a master key from which other keys are derived dynamically and used for a limited period of time



(a) Pairwise key hierarchy

- The three parts of the PTK are as follows.
- ■ EAP Over LAN (EAPOL) Key Confirmation Key (EAPOL-KCK): Supports the integrity and data origin authenticity of STA-to-AP control frames during operational setup of an RSN. It also performs an access control function: proof-of-possession of the PMK. An entity that possesses the PMK is authorized to use the link.
- ■ EAPOL Key Encryption Key (EAPOL-KEK): Protects the confidentiality of keys and other data during some RSN association procedures.
- ■ Temporal Key (TK): Provides the actual protection for user traffic.



(b) Group key hierarchy

Group Keys

- Group keys are used for multicast communication in which one STA sends MPDU's to multiple STAs. At the top level of the group key hierarchy is the group master key (GMK).
- The GMK is a key-generating key used with other inputs to derive the group temporal key (GTK). Unlike the PTK, which is generated using material from both AP and STA, the GTK is generated by the AP and transmitted to its associated STAs.
- Exactly how this GTK is generated is undefined

Pairwise Key Distribution. This exchange is known as the 4-way handshake.

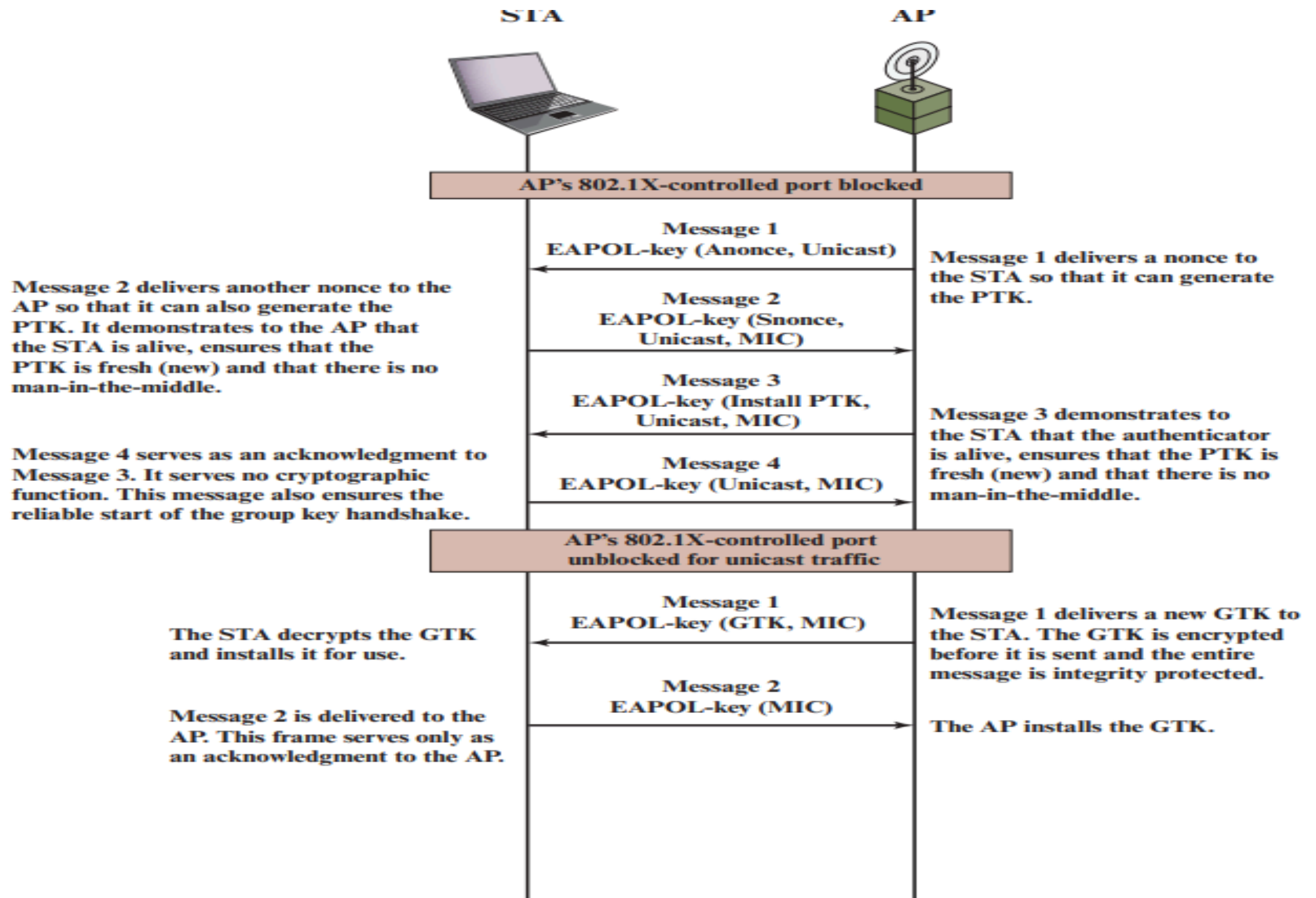


Figure 18.10 IEEE 802.11i Phases of Operation: Four-Way Handshake and Group Key Handshake

- PMK, verify the selection of the cipher suite, and derive a fresh PTK for the following data session. The four parts of the exchange are as follows.
 - AP S STA: Message includes the MAC address of the AP and a nonce (Anonce)
 - STA S AP: The STA generates its own nonce (Snonce) and uses both nonces and both MAC addresses, plus the PMK, to generate a PTK. The STA then sends a message containing its MAC address and Snonce, enabling the AP to generate the same PTK. This message includes a message integrity code (MIC)² using HMAC-MD5 or HMAC-SHA-1 [28]. The key used with the

- Group Key Distribution For group key distribution, the AP generates a GTK and distributes it to each STA in a multicast group.
- The two-message exchange with each STA consists of the following:
 - AP S STA: This message includes the GTK, encrypted either with RC4 or with AES. The key used for encryption is KEK, using a key wrapping algorithm (as discussed in Chapter 12). A MIC value is appended.

Protected Data Transfer Phase

- IEEE 802.11i defines two schemes for protecting data transmitted in 802.11 MPDUs: the Temporal Key Integrity Protocol (TKIP), and the Counter Mode-CBC MAC Protocol (CCMP).

Temporal Key Integrity Protocol (TKIP)

- TKIP is designed to require only software changes to devices that are implemented with the older wireless LAN security approach called Wired Equivalent Privacy (WEP).
- TKIP provides two services:
 - **Message integrity:** TKIP adds a message integrity code (MIC) to the 802.11 MAC frame after the data field. The MIC is generated by an algorithm, called Michael, that computes a 64-bit value using as input the source and

Counter Mode-CBC MAC Protocol (CCMP)

- CCMP is intended for newer IEEE 802.11 devices that are equipped with the hardware to support this scheme.
- As with TKIP, CCMP provides two services:
 - Message integrity: CCMP uses the cipher block chaining message authentication code (CBC-MAC)
 - Data confidentiality: CCMP uses the CTR block cipher mode of operation with AES for encryption.